

L2 - 8.1. Threat Hunting: Introduction

Task 1 - Introduction

The purpose of this room is to introduce Threat Hunting as a structured concept focusing on its relationship to Incident Response, the Threat Hunting mindset, and the specific goals that Threat Hunting strives to achieve.

Task 2 - Core Concept

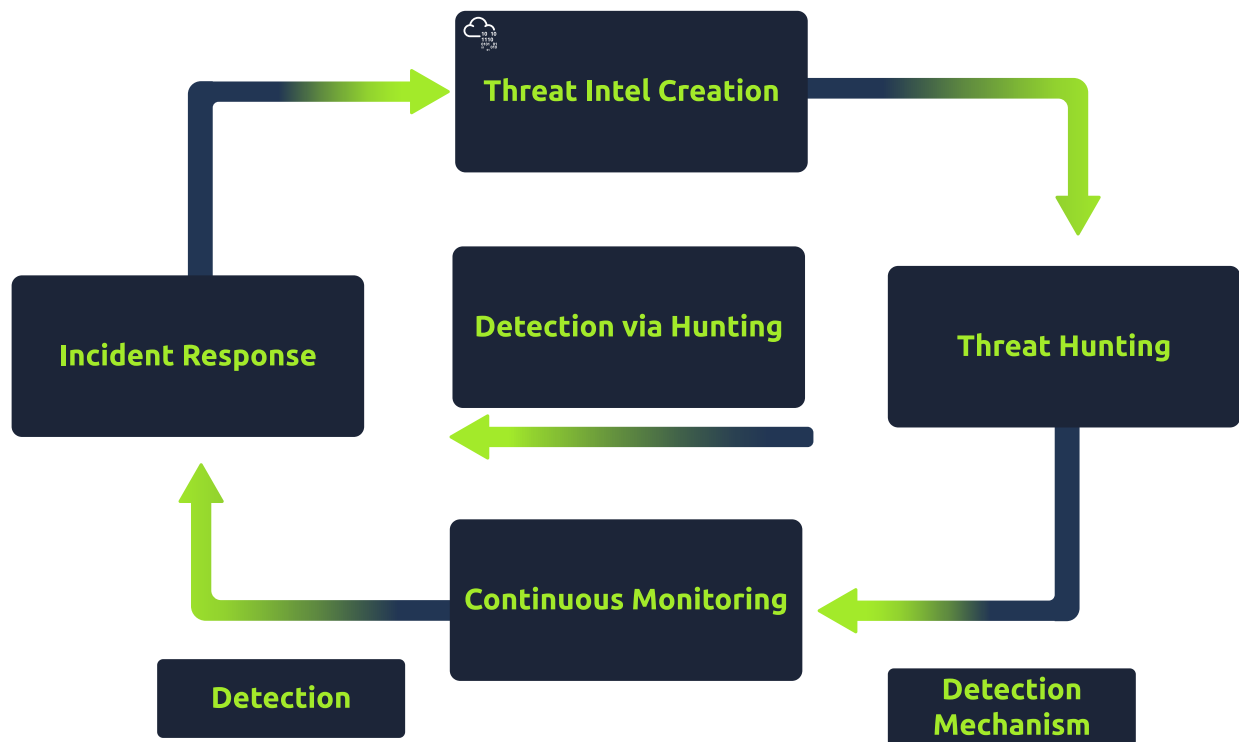
Threat hunting is an approach to finding cyber security threats where there's an active effort done to look for signs of malicious activity.

Incident Response (IR) is innately reactive. The action, or "response", is triggered by an initial notification or alert. This initial notification is first triaged, then analysed, and when enough pieces of evidence point to malicious activity, it is deemed an incident that needs to be responded to and dealt with accordingly.

Reactive Approach	Proactive Approach
Incident Response	Threat Hunting
Triggered by an initial notification / alert	Active search for suspicious events that can become incidents
Guided by the initial scope of the incident	Guided by Threat Intelligence
"There's a threat that needs to be dealt with now."	"There might be a threat that we don't know yet."

Threat Hunting aims to bridge this gap, constantly finding ways to add and improve the current detection mechanisms in place so that future similar bad behaviour will automatically be detected immediately. More so, during that process, detected threats go immediately to the Incident Response team. The trigger for their mobilisation are the findings from the Threat Hunt, and consequent findings from the IR process may steer the Threat Hunting team to further find bad behaviour.

This classic example shows the beauty of the synergy between two seemingly different approaches to ensuring one specific goal is met - strengthening the organisation's security posture.



Answer the questions below

What do you call the approach to finding cyber security threats where there's an active effort done to look for signs of malicious activity?

Threat hunting

In this task, what are we contrasting threat hunting with?

Incident response

Incident response is innately reactive. What is done first thing when an initial notification or alert is received? (It is _____.)

Triaged

Threat hunting is innately proactive. What is it guided by?

Threat Intelligence

Threat Hunting and Incident Response are two different approaches that aim to ensure one specific goal is met. It is to strengthen the organisation's what?

Security posture

Task 3 - Threat Hunting Mindset

It is imperative that we start our hunt with leads comprised of accurate pieces of information such as known relevant malware as well as trusted Threat Intelligence.

Understanding the bad that we may be dealing with is akin to knowing how they might behave within our environment, possibly allowing us to narrow down our search to specific sweet spots such as specific pieces of data they might be interested in, or even knowing which groups or APTs might be particularly interested in targeting us.

Intelligence on threats that you are able to develop internally is a very valuable asset to have. Not many organisations have the kind of intrusion experience that would allow them to study and develop usable intelligence from said intrusion and even fewer have the capability of developing it internally. Furthermore, intelligence of this kind may have the characteristic of being ultimately unique to your organisation.

Indicators of Compromise (IOCs) specifically documented on previous intrusions would be the most obvious and straightforward example for this one. IOCs immediately give value not only to your threat hunters but also to your detection mechanism, as they're actual traces of an adversary. Through this, re-intrusions of that specific adversary or other adversaries that employ the same tactics would be easier to spot.

As touched upon above, not a lot of organisations are capable of developing valuable and actionable Threat Intelligence internally. While a lot of organisations have their fair share of intrusions, not everyone has that kind of experience under their belt which allows them a front-row seat to a specific adversary's IOCs,

among others. More so, it involves a lot of money, skill, and effort to be able to become an efficient Threat Intelligence producer.

General Hunting Guide	Examples
Unique Threat Intelligence	Indicators of Compromise
Threat Intelligence Feeds	MISP Recorded Future Digital Shadows

Answer the questions below

What is the most obvious and straightforward example of a Unique Threat Intelligence?

Indicators of Compromise

Task 4 - Threat Hunting Process

What do we hunt for?

As the hunt progresses, the threat hunter will always go back to this question, ensuring that pieces of evidence that link to its answer are gathered.

1. Known Relevant Malware: The internet is ripe with known malware samples, and a lot of them have publicly available published analyses. One example of leveraging this kind of intelligence is to take a closer look at your organisation, identify the relevant threat actors that might take an interest in you, and hunt for traces of the malware that they use in their toolkits within your organisation.

The example above may be a bit general. Still, once you identify what is relevant to your organisation, it would be a lot more straightforward to narrow down the samples that you want and consequently hunt for their traces within the scope of your visibility.

2. Attack residues are a great starting point as well, especially if you think that an attack has happened already. It works particularly well with good Threat Intelligence as it would be as straightforward as ticking off a list of attack residues to check for within the environment.

The challenging part here, however, is knowing your environment well enough to be able to separate attack residues from normal behaviour. A lot of attack residues

blend well with normal environmental noise. Pair this with a more advanced adversary who knows how to clean up after themselves or even worse - employ tactics that are already stealthy from the get-go, and the hunt is suddenly not as straightforward as it seems.

3. Known Vulnerabilities of Products/Applications Being Used: Threat actors are quite creative in finding vulnerabilities and misconfigurations in the products and applications that their target organisation use. As such, at the very least, known vulnerabilities of assets should be actively hunted and patched accordingly. You might even stumble upon a threat actor actively exploiting your vulnerable assets, effectively catching 2 birds with one effort.

General Hunting Guide	Examples
Known Relevant Malware	theZoo (repository) Threat Encyclopedia
Attack Residues	Indicators of Attack Indicators of Compromise
Known Vulnerabilities	Zero-day Vulnerabilities CVEs

How do we hunt for it?

1. Attack Signatures and IOCs: Upon identifying the subject of the hunt, it's imperative that we ensure that we characterise them into specific and actionable identifiers by which we will immediately recognize. This is done most effectively via Attack Signatures and IOCs.
2. Logical queries: Some hunting projects are best accomplished via logical queries. A straightforward example of this one is hunting for assets that have known vulnerabilities.
3. Patterns of Activity

Answer the questions below

Malwares are constantly being used in the toolkits of threat actors. What is the live malware repository that we touched upon above?

theZoo

Knowing what is normal in your environment and separating them from what's not is a skill all threat hunters should have. What example of Threat Intelligence blends well with environmental noise?

Attack Residues

Threat actors are quite creative in finding vulnerabilities and misconfigurations. What should the organisation be extra vigilant in monitoring for announcements of?

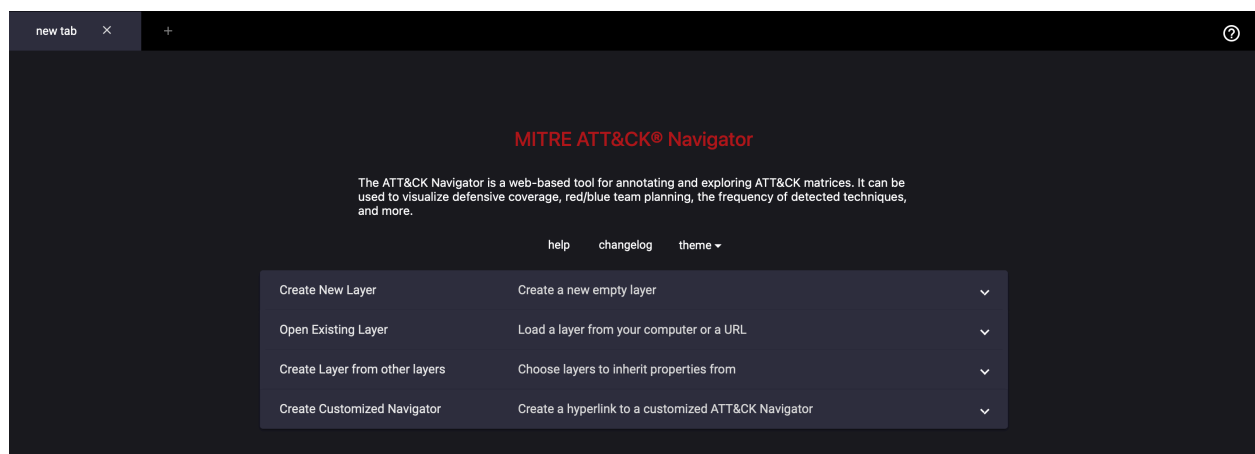
Zero-day vulnerabilities

Characterisation of the subject of the hunt into specific and actionable identifiers is imperative for the hunt's success. How is it done most effectively?

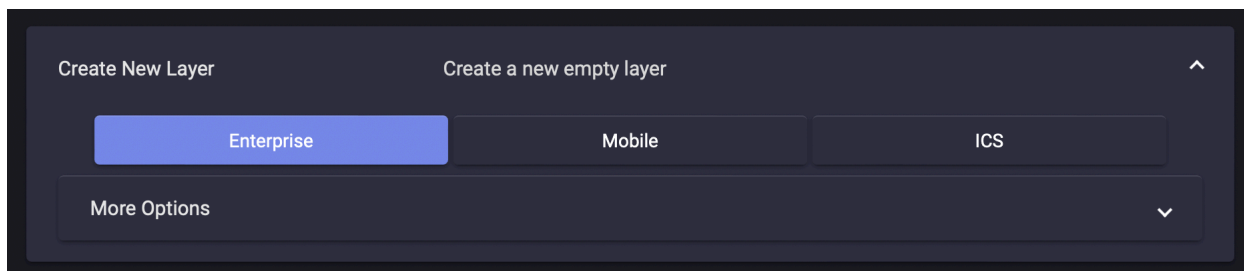
Attack Signatures and IOCs

Task 5 - Practical Application

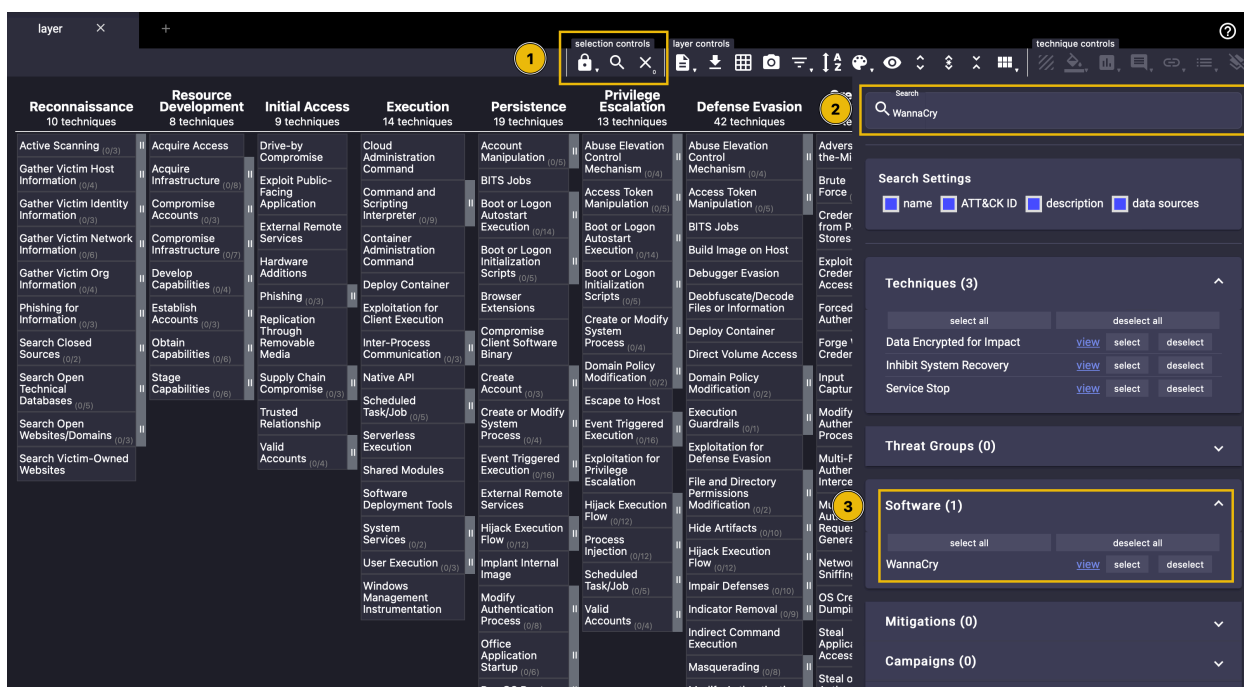
For our purposes, let's focus on the [MITRE ATT&CK Navigator](#)(opens in new tab). The ATT&CK Navigator is a tool designed to make it easier "to visualise your defensive coverage, your red/blue team planning, the frequency of detected techniques or anything else you want to do." Not only does it show the specific attack techniques that we should look for, but it also gives an idea of how an attack flows, and it shows it in a visually appealing way. The ATT&CK Navigator will be used to answer the questions in this task. If you haven't already done so, please click on the link provided.



The attack navigator landing page looks like this. Let's proceed by clicking on Create New Layer → Enterprise. This should show you a blank ATT&CK Navigator page.



Select the magnifier glass under "selection controls", and then type "WannaCry" inside the search bar. The "Software" part of the results should show 1 result. Click on the "select" button beside the result.



It should then show something like this:

layer		selection controls		layer controls		technique controls					
Access techniques	Execution 14 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques	Discovery 31 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 16 techniques	Exfiltration 9 techniques	Impact 13 techniques
by promise	Cloud Administration Command	Account Manipulation (0/5)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)	Account Discovery (0/4)	Exploitation of Remote Services	Adversary-in-the-Middle (0/3)	Application Layer Protocol (0/4)	Automated Exfiltration (0/7)	Account Access Removal
Public-	Command and Scripting Interpreter (0/9)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (0/3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
al Remote	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Boot or Logon Autostart Execution (0/14)	BITS Jobs	Credentials from Password Stores (0/8)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Automated Collection	Exfiltration Over Alternative Protocol (0/3)	Data Encrypted for Impact
are ns	Deploy Container	Boot or Logon Initialization Scripts (0/8)	Boot or Logon Initialization Scripts (0/8)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)	Browser Session Hijacking	Data Encoding (0/2)	Exfiltration Over C2 Channel	Data Manipulation (0/3)
g (0/3)	Exploitation for Client Execution	Browser Extensions	Create or Modify System Process (0/4)	Debugger Evasion	Forge Web Credentials (0/2)	Cloud Service Dashboard	Remote Services (0/7)	Clipboard Data Hijacking	Data Obfuscation (0/5)	Exfiltration Over Other Network Medium (0/1)	Defacement (0/2)
tion in	Inter-Process Communication (0/3)	Compromise Client Software Binary	Domain Policy Modification (0/2)	Deobfuscate/Decode Files or Information	Direct Volume Access	Cloud Storage Object Discovery	Replication Through Removable Media	Data from Cloud Storage	Dynamic Resolution (0/3)	Exfiltration Over Physical Medium (0/1)	Disk Wipe (0/2)
able	Native API	Create Account (0/3)	Escape to Host	Deploy Container	Input Capture (0/4)	Container and Resource Discovery	Software Deployment Tools	Encrypted Channel (0/2)	Fallback Channels	Exfiltration Over Web Service (0/3)	Endpoint Denial of Service (0/4)
Chain omise (0/3)	Scheduled Task/Job (0/8)	Create or Modify System Process (0/16)	Event Triggered Execution (0/16)	Direct Volume Access	Modify Authentication Process (0/8)	Debugger Evasion	Taint Shared Content	Data from Configuration Repository (0/2)	Ingress Tool Transfer	Scheduled Transfer	Firmware Corruption
hship	Serverless Execution	Event Triggered Execution (0/16)	Exploitation for Privilege Escalation	Domain Policy Modification (0/2)	Multi-Factor Authentication Interception	Device Driver Discovery	Use Alternate Authentication Material (0/4)	Data from Information Repositories (0/3)	Multi-Stage Channels	Exfiltration Over Physical Medium (0/1)	Inhibit System Recovery
ts (0/4)	Shared Modules	External Remote Services	Hijack Execution Flow (0/12)	Execution Guardrails (0/1)	Multi-Factor Authentication Request Generation	Domain Trust Discovery		Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	Resource Hijacking
	Software Deployment Tools	Hijack Execution Flow (0/12)	Process Injection (0/12)	File and Directory Permissions Modification (0/2)	Hide Artifacts (0/10)	File and Directory Discovery		Data from Network Shared Drive	Non-Standard Port	System Shutdown/Reboot	
	System Services (0/2)	Implant Internal Image	Scheduled Task/Job (0/8)	Hide Artifacts (0/10)	Hijack Execution Flow (0/12)	Group Policy Discovery		Data from Removable Media	Protocol Tunneling		
	User Execution (0/2)	Modify Authentication Process (0/8)	Valid Accounts (0/4)	Impair Defenses (0/10)	Indicator Removal (0/9)	Network Sniffing		Data Staged (0/2)	Proxy (0/4)		
	Windows Management Instrumentation	Office Application Startup (0/6)		Indirect Command Execution	Masquerading (0/8)	Network Service Discovery		Email Collection (0/3)	Remote Access Software		
		Pre-OS Boot (0/5)		Masquerading (0/8)	Modify Authentication	Network Share Discovery		Input Capture (0/4)	Traffic Signaling (0/2)		
				Masquerading (0/8)		Password Policy Discovery		Screen Capture	Web		

To better visualise our selection, select a background colour under “technique controls”. It will immediately fill the selected techniques with the colour of your choice. Let's also set an arbitrary score of 1 for this layer, the control for which is beside the background colour, still under the “technique controls”. Finally, we can set a name for this layer by editing the layer information under “layer controls”. It should look something like this. Take note that hovering on the technique should show the score.

WannaCry + Stuxnet + Conficker X												
selection controls												
layer controls												
technique controls												
Initial Access 9 techniques	Execution 14 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques	Discovery 31 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 16 techniques	Exfiltration 9 techniques	Impact 13 techniques	
Drive-by Compromise	Cloud Administration Command	Account Manipulation (0/5)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)	Account Discovery (2/4)	Exploitation of Remote Services	Adversary-in-the-Middle (0/3)	Application Layer Protocol (1/4)	Automated Exfiltration (0/1)	Account Access Removal	
Exploit Public-Facing Application	Command and Scripting Interpreter (0/9)	BITS Jobs	Access Token Manipulation (1/5)	Access Token Manipulation (1/5)	Brute Force (0/4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (1/3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction	
External Remote Services	Container Administration Command	Boot or Logon Autostart Execution (1/14)	Boot or Logon Autostart Execution (1/14)	BITS Jobs	Credentials from Password Stores (0/5)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Exfiltration Over Alternative Protocol	Exfiltration Over Alternative Protocol	Data Manipulation	
Hardware Additions	Deploy Container	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (1/2)	Automated Collection	Data Encoding (1/2)	Exfiltration Over C2 Channel	Defacement	
Phishing (0/2)	Exploitation for Client Execution	Browser Extensions	Deobfuscate/Decode Files or Information (0/5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (1/7)	Browser Session Hijacking	Data Obfuscation (0/3)	Exfiltration Over C2 Channel	Disk Wipe (0/2)	
Replication Through Removable Media	Inter-Process Communication (0/3)	Compromise Client Software Binary	Create or Modify System Process (1/4)	Deploy Container	Forge Web Credentials (0/2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (1/3)	Exfiltration Over Other Network Medium (0/1)	Endpoint Denial of Service (0/4)	
Supply Chain Compromise (0/2)	Native API	Create Account (0/2)	Domain Policy Modification (0/2)	Direct Volume Access	Input Capture (0/4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2/2)	Exfiltration Over Physical Medium (0/1)	Firmware Corruption	
Trusted Relationship	Scheduled Task/Job (1/5)	Create or Modify System Process (1/4)	Event Triggered Execution (0/18)	Execution Guardrails (0/7)	Modify Authentication Process (0/8)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (0/2)	Fallback Channels	Exfiltration Over Web Service (0/3)	Inhibit System Recovery	
Valid Accounts (2/4)	Serverless Execution	Event Triggered Execution (0/7/6)	Exploitation for Privilege Escalation	Exploitation for Defense Evasion	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material (0/4)	Data from Information Repositories (0/3)	Ingress Tool Transfer	Exfiltration Over Web Service (0/3)	Network Denial of Service (0/2)	
	Shared Modules	External Remote Services	Hijack Execution Flow (0/12)	File and Directory Permissions Modification (1/2)	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Multi-Stage Channels	Scheduled Transfer	Resource Hijacking	
	Software Deployment Tools	Hijack Execution Flow (0/12)	Process Injection (1/12)	Hide Artifacts (1/10)	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reset	
	System Services (0/2)	Implant Internal Image	Scheduled Task/Job (1/5)	Impair Defenses (1/6)	OS Credential Dumping (0/8)	File and Directory Discovery		Data from Removable Media	Non-Standard Port			
	User Execution (0/3)	Modify Authentication Process (0/8)	Valid Accounts (2/4)	Indirect Command Execution	Steal Application	Group Policy Discovery		Data Staged (0/2)	Proxy (2/4)			
	Windows Management Instrumentation					Network Service Discovery		Email Collection (0/1)	Remote Access Software			

The differing colours are set to be able to immediately see which common tactics or techniques these threat actors share. A deep red colour means it's common to all of them, while the other lighter colours mean it's either one or any combination of two threat actors. The scores are arbitrary, and you can set them in terms of relevance to your organisation or just random if you just intend to play around with the tool visually. Questions at the end of this task would be related to this specific ATT&CK Navigator layer.

These tools and resources at hand would allow for a more straightforward approach to identifying patterns of activity. Once we're satisfied with the way we've characterised the relevant threats that we wanted to focus on, we can then start hunting. This intelligence-driven approach of characterising threat actor behaviour through their TTPs is one of, if not the best, way to go about hunting. It immediately gives value to the hunt, and it's sensible, straightforward, and actionable.

MITRE has done a lot, not only within the cyber security sphere but also in subjects that generally help build a "safer world". For more information on what MITRE has to offer, albeit, in the cyber security industry, you may head over to the [MITRE room](#).

When do we decide to move on?

The single biggest challenge in Threat Hunting is knowing when to decide to move on to other things. When will you know you're done with it? Here's a Capture the Flag (CTF) analogy.

In CTFs, you immediately know before you even start that by the end of it, if you do everything right, there will be a flag waiting for you. If you aren't able to get the answer, that just means that you need to study more and further improve so that the next time you tackle a similar problem, you'll have more chances of capturing that flag. That's not necessarily the case for Threat Hunting. It's completely possible, and even more probable than not, that you do everything right and not find anything.

It will be normal to feel inadequate - there will always be internal doubt when hunting for threats. But as long as you follow your processes, especially with a hunting plan that's intelligence-driven, you should be fine.

Answer the questions below

| Which tactic has the most techniques highlighted?

Discovery

| Which technique does the three threats have in common?

Exploitation of Remote Services

| What technique does WannaCry and Conficker have in common?

Inhibit System Recovery

| What's the score of techniques that Stuxnet and Conficker have in common?

6

Task 6 - Goals

So far, we have talked about the Threat Hunting concept, as well as the whats, the hows, and even the whens behind the Threat Hunting mindset; now it's time to talk about the whys.

Proactive Approach to Finding Bad

Threats are one of the constants in the world of security. There will never be a shortage of malicious actors, from Script Kiddies to well-funded Advanced Persistent Threats. There will always be someone snooping around your environment, and with that in mind, it is imperative that you find them first and you find them fast, ideally before they are able to do what they set out to do.

Discover Pre-existing Bad

Through complex and sophisticated attack chains, chance, or even mere luck, it is a reality that some activities of malicious actors may slip through an organisation's detection mechanisms. In that sense, similar kinds of activities are essentially undetectable; however, they are not invisible. It's just that detection mechanisms haven't yet been developed to automatically flag these activities.

It is through Threat Hunting that we're able to find these activities, and upon such discovery, it will consequently (and quite immediately) trigger an Incident Response. These learnings will ultimately be fed back to the continuous monitoring process of the SOC (see last section).

Minimise the Dwell Time of Attackers

Another byproduct of undetected threat actor activity is having essentially a 'free pass' to further snoop around within the environment. The longer a bad actor has access to your environment, the more opportunities they have to further learn about it. With a deeper understanding of the environment, an attacker may execute more sophisticated ways of persisting within the environment, cause bigger damage to important assets and/or information, and steal more data.

The primary goal of Threat Hunting is to minimise a threat actor's dwell time. Ultimately, security is the business of ensuring the confidentiality, integrity, and availability of the organisation's assets, and minimising dwell time also minimises the damage a threat actor might have already caused.

Develop Additional Detection Methods

In the end, we want to be able to use all of these findings as feedback to our continuous monitoring process. Security is a continuous development process, so we wouldn't want to hunt for the same threats over and over again. Instead, once we've profiled threats that were previously undetectable by current detection methods, an effort should immediately be poured into translating these profiles

into detection mechanisms. In effect, future similar threats will be immediately detected and actioned upon.

Answer the questions below

| What is the primary goal of Threat Hunting?

Minimise a threat actor's dwell time

| Feedback is important to keep the organisation secure. Upon profiling threats through our Threat Hunting efforts, what should these profiles be translated to?

Detection mechanisms

Task 7 - Conclusion

Now that you're aware of the baseline considerations that go with Threat Hunting, it's time to get your hands dirty and flex your Threat Hunting skills.